

Team Soda

AI Passport (Safe AI for Every Employee)

Case Study Category: 3 — AI Governance & Responsible AI in Enterprise

Yeap Boon Shen, Lee Jia Yin, Muhammad Ikhlas Bin Mohd Faizal, Samantha Chan Pei Yin

1. Introduction

AI Passport is a web platform and browser extension that lets companies say "yes" to AI instead of "no". Today, employees already use ChatGPT, Gemini and other AI tools at work, with or without permission. Banning these tools does not work; it only pushes the usage underground, where the company cannot see it. AI Passport makes the safe way the easy way: employees keep using AI and staying productive, while the company keeps full visibility and control over its data.

The platform has **five main features**:

- **AI License (gamified training):** employees complete 5-minute micro-trainings and quizzes to level up. Higher levels unlock more powerful AI tools and more data categories, always within the employee's job role. Unsafe behaviour, like pasting customer data, reduces points.
- **Smart Gateway "Mask, don't Block":** a browser extension scans every prompt before it is sent to an AI tool and **masks sensitive data in real time** (an IC number becomes [MASKED-IC]). The employee still gets a useful AI answer; the company's data never leaves.
- **Admin Dashboard:** management sees AI usage by department, risk alerts and a full audit log, with a **one click compliance report** mapped to the NIST AI RMF, the EU AI Act and Malaysia's PDPA.
- **AI Tool Approval Workflow:** employees request a new tool in one simple form; IT approves it **in days, not months**. Unapproved usage is never punished — the system suggests the approved alternative with one click.
- **Disclosure & Human-Review Page:** anyone affected by an AI-assisted decision can learn that AI was involved, read a simple explanation, and **request a human review**.

Key technologies: a **React** web app, a **Chrome extension**, a **Node.js + Firebase** backend, and the **Google Gemini API** combined with rule-based detection to identify sensitive data in prompts.

2. Problem Statement

Companies are losing control of their data because of **shadow AI**: employees using AI tools that the company has never approved. The "attacker" is not a hacker; it is an **ordinary employee who just wants to finish work faster**. One copy-and-paste into a chat window can send customer records or financial data outside the company in seconds, with no record it ever happened.

We have seen this problem firsthand. One of our team members interns at a financial-sector IT services company where an approved AI coding agent is provided but under heavy restrictions: installing any new AI extension requires admin approval that can take weeks and the development environment force-closes on certain file operations. The approved tool exists yet using it is slow and frustrating. This is exactly how shadow AI starts: when the safe path is harder than the unsafe one, employees quietly switch to personal AI accounts. The lesson shaped our design security controls must protect data **without breaking the employee's workflow**, which is why AI Passport masks instead of blocks and approves tools in days instead of weeks.

The scale of the problem is well documented:

- Up to **65% of employees** bypass IT and use unauthorised AI tools at work [1].
- **22% of files and 4.4% of prompts** submitted to generative AI tools contain sensitive data such as customer records and internal financials [2].
- Breaches involving shadow AI cost an average of **USD 4.63 million per breach** more than conventional breaches, because detection is slower and visibility is limited [1].
- The average enterprise records around **223 AI-related policy violations every month** [1].

Everyone is affected. **Employees** risk leaking data without realising it. **IT and compliance teams** cannot govern tools they cannot see. **Management** carries the legal

and financial exposure. **Customers and job applicants** face AI-assisted decisions without knowing AI was involved, and with no way to ask for a human review.

Regulation is making inaction impossible. **Article 4 of the EU AI Act**, in force since August 2025, legally requires companies to train staff in AI literacy, with fines up to **EUR 7.5 million or 1% of global turnover** [3]. Malaysia is moving in the same direction through the **PDPA 2010** [7] and the **National Guidelines on AI Governance and Ethics** [8]. Yet existing governance platforms are built and priced for large corporations [4][5], so most companies, especially SMEs, can afford none of them.

In short: employees will not stop using AI and bans only push the problem underground. Evidence shows unauthorised use drops sharply once an approved path is provided [6]. What is missing is an affordable system that **guides employees instead of punishing them**. That is the gap AI Passport fills.

3. Aim and Objectives

To develop an affordable AI governance platform that enables employees to use AI tools safely and productively, while giving organisations full visibility of AI usage, real-time data protection, transparent and accountable AI-assisted decisions, and audit-ready compliance - directly addressing the three key challenges of responsible AI adoption in enterprise.

To achieve this aim, the project sets six measurable objectives:

1. **To develop a gamified AI License module** with at least 3 license levels, 5-minute micro-training lessons and quizzes, where higher levels unlock more powerful AI tools and more sensitive data categories, building willing employee compliance instead of forced rules. (Challenge 1: Responsible AI Usage & Employee Compliance)
2. **To develop a browser-based Smart Gateway** that detects and masks at least 5 categories of sensitive data (IC/passport numbers, personal names, phone numbers, financial figures, credentials) in real time before a prompt leaves the browser, achieving at least 90% detection accuracy on a labelled test set of 100 prompts. (Challenge 2: Data Privacy & Security)
3. **To develop an admin dashboard** that displays AI usage by department and user, raises risk alerts including data leakage and high-risk AI use involving decisions about people, maintains a

complete audit log, and generates a one-click compliance report mapped to the NIST AI RMF [9], the EU AI Act and Malaysia's PDPA. (Challenge 2; Use case 1)

4. **To implement an AI tool approval workflow** that reduces approval time from months to days and redirects unapproved tool usage to an approved alternative through a one-click switch. (Challenge 1; Use case 2)
5. **To implement an AI disclosure and human-review page** where any person affected by an AI-assisted decision can learn that AI was involved and request reconsideration by a person. (Challenge 3: Transparency & Ethical Boundaries)
6. **To deliver a working end-to-end prototype within the 7-day hackathon period**, validated with at least 10 pilot users and measured against the accuracy and usability targets above.

Objective	Feature Delivered	Case Study Challenge Addressed
O1	AI License (gamified training)	Challenge 1: Responsible AI Usage & Employee Compliance
O2	Smart Gateway ("Mask, don't Block")	Challenge 2: Data Privacy & Security
O3	Admin Dashboard + one-click compliance report	Challenge 2; Use Case 1 (monitor AI risks) & Use Case 3 (usage dashboard)
O4	AI Tool Approval Workflow	Challenge 1; Use Case 2 (approval workflow)
O5	Disclosure & Human-Review Page	Challenge 3: Transparency & Ethical Boundaries
O6	Working end-to-end prototype	Validates all three challenges in practice

4. Methodology

4.1 Implementation

The system is developed in three stages across the 7-day hackathon. Each component is tagged to the objective it delivers (O1–O6 from Section 3), ensuring full traceability between what we promised and what we build.

Stage 1: Prototype Development (Days 1–3). We finalise the concept, confirm the MVP scope and design all key screens in Figma: the AI License card and training quiz (O1), the

Smart Gateway masking pop-up (O2), the admin dashboard and audit report (O3), the tool approval form (O4), and the disclosure/review-request page (O5). In parallel, we de-risk the most technically uncertain component first: we verify that the Gemini API can reliably classify sensitive text, and we build a labelled test set of 100 prompts (50 safe, 50 containing sensitive data) that becomes our benchmark for O2's 90% accuracy target.

Stage 2: Implementation (Days 3–5). We build three components connected through one shared Firebase backend (Figure 1):

(a) **The web application (React)** - login, AI License profile and training module (O1), approval workflow (O4), admin dashboard (O3), and the public disclosure and human-review request page, linked to the audit log (O5).

(b) **The Chrome extension - Smart Gateway (O2)** - intercepts prompt text on AI tool pages, sends it to the detection service, and replaces sensitive content with masked tokens (e.g. an IC number becomes [MASKED-IC]) before the prompt is submitted. The employee still receives a useful AI answer; the raw data never leaves the browser.

(c) **The detection service (O2, O3)** - a two-layer design balancing speed and intelligence. Layer 1: rule-based patterns (regex) for structured data such as IC and phone numbers fast and free. Layer 2: the Gemini API for context-aware detection of names, confidential topics, and intent. Every detection event is written to the audit log, updates the employee's license points (O1), and refreshes the admin dashboard in real time via Firestore (O3).

Stage 3: Testing & Refinement (Days 5–7). We validate the system through three tests:

- **Detection accuracy (O2):** run the 100-prompt benchmark, measure accuracy against the 90% target, and tune rules and prompts accordingly.
- **Pilot usability (O6):** at least 10 pilot users complete 3 tasks each (finish one training quiz, submit a prompt containing fake sensitive data, request a tool approval); we log task completion rates and collect feedback.
- **End-to-end check (O3, O5):** verify that each masked prompt appears in the audit log, triggers the correct dashboard update, and appears correctly in the one-click compliance report.

Finally, we polish the UI to the Figma design, record the demo video and finalise the repository and deployment.

Risk mitigation. We identified three main risks and prepared a fallback for each. If the Gemini API misclassifies, the regex layer still catches all structured data, so protection degrades gracefully and never fails completely. If the Chrome extension is blocked on some AI sites, the web app includes a "safe prompt box" as an alternative entry point. If we run out of time, features are built in objective order (O2 first, O5 last), so the core protection always ships.

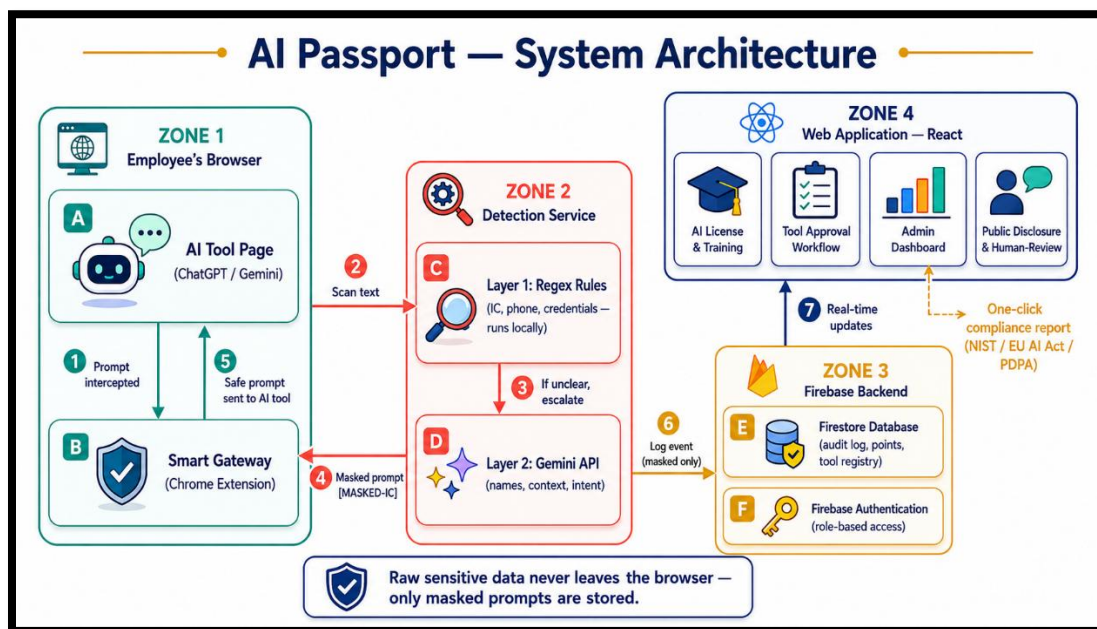


Figure 1: AI Passport system architecture

4.2 Tech Stack

Layer	Technology	Why we chose it
Frontend	React + Tailwind CSS	Fast to build, clean and consistent UI
Browser Extension	Chrome Extension (JavaScript, Manifest V3)	Runs directly inside AI tool pages
Backend	Node.js (Express) + Firebase Authentication	Simple, real-time, secure login

Database	Firebase Firestore	Live dashboard updates without polling
AI / ML	Google Gemini API + rule-based (regex) detection	Context-aware intelligence + fast, cheap structured detection
Design	Figma	Wireframes and high-fidelity UI
Deployment	Vercel (web) + Firebase Hosting	Free tier, instant deploy

Privacy by design. The gateway masks data locally in the browser wherever possible; only masked prompts, never raw sensitive data, are stored in the audit log; all traffic uses HTTPS; and dashboard access is role-based (employee vs admin). A governance tool must itself be governable: our own audit log is safe to audit.

5. Potential Impact

AI Passport lets organisations adopt generative AI without choosing between employee productivity and organisational control. Employees receive a clear list of approved tools, short training, and real-time guidance: when sensitive information is detected, the Smart Gateway masks it and explains why, so work continues with minimal interruption. Management, IT and compliance teams gain a central view of AI activity: which tools are used, by which departments, what risks were detected, and whether action was taken. The approval workflow records the purpose, owner, data category and decision for each requested tool, and the disclosure page gives people affected by AI-assisted decisions a practical way to understand the outcome and request a human review. Together, these capabilities directly answer the case study's three challenges.

Impact Area	Expected Outcome	Measurable Indicator
Employee Awareness	Employees understand safe and acceptable AI use	Training completion and quiz pass rate
Data Protection	Fewer sensitive-data exposures through AI prompts	Number and % of risky prompts masked
AI Visibility	Management sees approved and unapproved tool usage	Number of tools and use cases recorded

Governance Efficiency	Tool requests and risk reviews completed faster	Average approval and review time (days, not months)
Transparency	Affected individuals can identify and challenge AI-assisted decisions	% of applicable decisions with disclosure and review access

5.1 Market Research

Market need. The rapid adoption of generative AI has created clear demand for tools that show organisations how employees use AI, what information is shared, and whether policies are followed. Established enterprise products such as Microsoft Purview and Credo AI already provide AI discovery, data protection and compliance evidence [5], which confirms that AI governance is a recognised and growing technology market. However, smaller organisations face a practical gap between having an AI policy on paper and enforcing it during everyday work. A written policy does not identify sensitive information before it is shared, guide employees towards approved tools, or maintain evidence of how AI is actually used. AI Passport closes this gap by placing governance controls directly inside the employee's workflow.

Malaysia provides a substantial initial market. In 2024, Malaysia had 1,086,386 micro, small and medium enterprises, representing 96.1% of all business establishments and contributing approximately RM652.4 billion, or 39.5%, of national GDP [10]. Even a small share of this market represents a meaningful customer base for a lightweight, affordable governance platform. The most suitable early customers are digitally active SMEs that already use generative AI but have no specialised governance team: professional-service firms, software companies, recruitment agencies, private education providers, healthcare administrators, e-commerce businesses, marketing agencies and financial-service intermediaries. These organisations routinely handle customer, financial or commercially sensitive information, where a single accidental disclosure through an AI tool could create serious legal and reputational consequences.

Existing solutions and competitor comparison:

Competitor	What they do	Their gap
Harmonic Security [4]	Browser-based GenAI protection: detects and redacts sensitive data in prompts, guides employees in real time	Enterprise-only pricing; no training or gamification; not localised for Malaysia
Credo AI / Holistic AI [5]	Full AI governance platforms with policy packs (EU AI Act, NIST) and approval workflows	Built for large corporations; complex and expensive; no real-time prompt protection
Lasso / LayerX [6]	Shadow AI discovery and DLP for browser-based AI usage; masks or blocks sensitive content	Focus on blocking and monitoring; punishes instead of guiding employees

What makes AI Passport unique. Four choices separate us from every product above. First, we mask instead of block: frequent blocking interrupts work, so AI Passport masks only the sensitive parts of a prompt and the employee still gets the AI answer without resending it, delivering productivity and protection at the same time. Second, we offer the only gamified AI License: AI literacy training is now a legal requirement under EU AI Act Article 4 [3], and our license levels, points and leaderboard turn that legal burden into an engagement feature, while actual data access always remains controlled by job role and data classification. Third, we are built for SMEs and for Malaysia, with affordable subscription pricing and Malaysia-focused policy templates aligned with PDPA 2010 [7] and the AIGE guidelines [8], a segment global enterprise vendors ignore. Fourth, we guide instead of punish: unapproved tool usage triggers a one-click switch to the approved alternative, following evidence that providing an approved path sharply reduces unauthorised use [6].

Commercial feasibility. AI Passport operates as a tiered SaaS subscription based on active users: Starter for micro and small businesses (training, approved-tool list, basic masking), Growth for SMEs (full dashboard, approval workflow, audit evidence), and Enterprise/Partner for larger firms and consultants (custom policies, integrations, multi-organisation management). The growth path expands from the Chrome extension and web dashboard to workplace platform integrations, a secure API gateway for internal AI systems, and AI-agent monitoring, keeping the prototype focused while showing a sustainable product beyond the hackathon.

5.2 Target Users

SME owners and senior management use the dashboard to understand how AI is being adopted across the organisation. They review risk trends by department, monitor training completion, and

identify which tools require formal approval, gaining enterprise-grade visibility without hiring a compliance team.

Department managers review AI use cases within their own teams and approve or reject requests with business context: a marketing manager may approve AI-assisted content drafting but reject the use of customer contact lists in a public chatbot. This distributes responsibility to the people who understand the work.

Employees see exactly which tools are approved, complete short training scenarios, level up their AI License, and work safely. When a risk is detected, the platform explains the issue in plain language and suggests a safer next step instead of showing a technical warning.

Customers, applicants and other affected individuals use the public disclosure page to learn that AI contributed to a decision about them, read a plain-language explanation, and request a human review, creating a practical redress pathway that strengthens trust.

External auditors and business partners may receive limited access to governance evidence such as approved-tool records, training summaries and policy mappings, but never raw employee prompts, supporting privacy while allowing the organisation to demonstrate its governance process.

6. Prototype Interface (Appendix)

The interactive Figma wireframe of AI Passport is available at:
<https://www.figma.com/design/hvtRnwmiJKGEG1g0mzJBLE/Soda?node-id=0-1&p=f&t=fJGBdaOBrORb2cJw-0>

The interactive Figma prototype of AI Passport is available at:
<https://www.figma.com/proto/hvtRnwmiJKGEG1g0mzJBLE/Soda?node-id=12-25&t=pdhKDNcGU3aGBKEW-0&scaling=min-zoom&content-scaling=fixed&page-id=0%3A1>

7. References

- [1] Technology Radius (2026). 20 Shadow AI Statistics 2024–2026: Enterprise AI Risk. <https://technologyradius.com/statistic/shadow-ai-statistics-2024-2026>
- [2] Harmonic Security / Business Wire (2025). 22% of All Files and 4.37% of Prompts Submitted to GenAI Tools by Employees Contain Sensitive Data. <https://www.morningstar.com/news/business-wire/20250731456105>
- [3] European Union (2024). EU Artificial Intelligence Act, Article 4: AI Literacy. <https://artificialintelligenceact.eu/article/4/>
- [4] Harmonic Security (2026). Browser-Based GenAI Security & Real-Time Protection. <https://www.harmonic.security/solutions/browser-based-genai-security>
- [5] Credo AI (2026). The Trusted Leader in AI Governance — Product. <https://www.credo.ai/product>
- [6] Lasso Security (2026). What is Shadow AI? Risks, Tools, and Best Practices for 2026. <https://www.lasso.security/blog/what-is-shadow-ai>
- [7] Government of Malaysia (2010). Personal Data Protection Act 2010 (Act 709).
- [8] Ministry of Science, Technology and Innovation Malaysia (2024). National Guidelines on AI Governance and Ethics (AIGE).
- [9] National Institute of Standards and Technology (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0). <https://doi.org/10.6028/NIST.AI.100-1>
- [10] SME Corporation Malaysia (2025). Profile of MSMEs in 2015–2024. <https://www.smecorp.gov.my/index.php/en/policies/2020-02-11-08-01-24/profile-and-importance-to-the-economy>